

Documentation-Driven Threat Analysis

S1.5 Working Note

Requirement abstraction and provenance constraints

Formalizzazione temporanea tra SpecializedRequirement S1 e SecurityRequirement S2

Stato. Materiale di ricerca temporaneo. Non costituisce un capitolo autonomo della tesi, non promuove ancora una nuova foundation canonica e non chiude il modello di AnalysisRecord, Finding, revision o change event.

Baseline repository. nballestriero/documentation-driven-threat-analysis, commit 9108917d1ca6dfa030df6625018520db0b05f6bf.

Scopo. Verificare una possibile astrazione comune Requirement [abstract] per FunctionalRequirement e SpecializedRequirement e registrare i vincoli minimi che il futuro modello di provenance dovrà soddisfare.

Indice

1	Perche' esiste questa nota	1
2	Collocazione futura nella tesi	1
	Parte A - Requirement abstraction	3
3	Ipotesi S1.5-A	3
4	Significato di NormativeObligation	3
5	FunctionalRequirement come specializzazione	4
6	SpecializedRequirement come specializzazione	4
7	Regression probes	5
7.1	Negative control - Decision	5
8	Stato candidato S1.5-A	5
	Parte B - Provenance constraints	7
9	Confine ereditato da S1	7
10	Analysis-to-document provenance requirement	7
11	Invarianti di provenance preservabili ora	7
11.1	P1 - Provenance separation	7
11.2	P2 - Historical multiplicity	8
11.3	P3 - Analysis is not governance authority	8
11.4	P4 - Analyzed is not changed	8
12	Meccanismo strutturale deliberatamente OPEN	8
13	Acceptance queries per il futuro modello	9
13.1	Analysis verso accepted changes	9
13.2	Governed document verso analysis lineage	9
14	Stato epistemico S1.5	9
15	Prossimo microstep raccomandato	10

1 Perché esiste questa nota

S1 ha chiuso la semantica di `SpecializedRequirement` come rafforzamento normativo governato di esattamente un `FunctionalRequirement`. La baseline corrente mantiene tuttavia una asimmetria strutturale:

```
FunctionalRequirement
  functionalObligation
  functionalClause 1..*

SpecializedRequirement
  normativeObligation
```

La prima domanda S1.5 è quindi più stretta della semantica di `SecurityRequirement`:

FunctionalRequirement e SpecializedRequirement condividono un contratto astratto comune di Requirement?

In parallelo è emersa una seconda domanda, distinta:

Come deve DDTA preservare il fatto che una analisi abbia contribuito all'introduzione, revisione, sostituzione o retirement di documentazione governata?

Le due domande non devono essere fuse:

```
requirement semantics
  !=
analysis/change provenance
```

2 Collocazione futura nella tesi

Questo materiale non giustifica un capitolo autonomo. La consolidazione più plausibile è una sezione del Capitolo 4 dedicata alla struttura comune della documentazione governata e, al suo interno o immediatamente dopo, una sottosezione sull'astrazione comune dei Requirement.

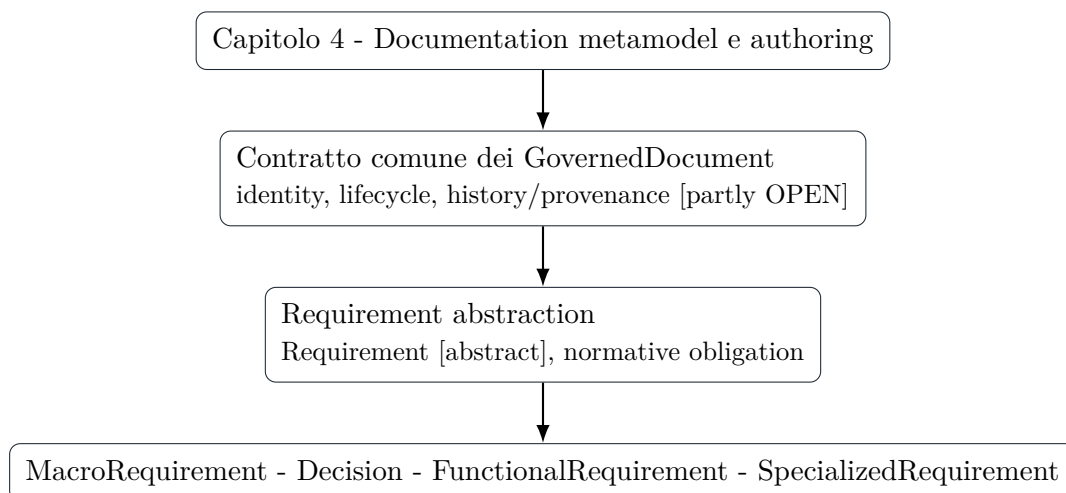


Figura 1: Collocazione futura proposta. Requirement non coincide con GovernedDocument.

La distinzione da preservare è:

- **GovernedDocument** possiede proprieta' trasversali a tutti i documenti governati;
- **Requirement** accomuna soltanto i documenti che stabiliscono una obbligazione normativa;
- history/provenance e' piu' generale di Requirement e non deve essere confinata a SpecializedRequirement.

Parte A - Requirement abstraction

3 Ipotesi S1.5-A

L'ipotesi da falsificare e':

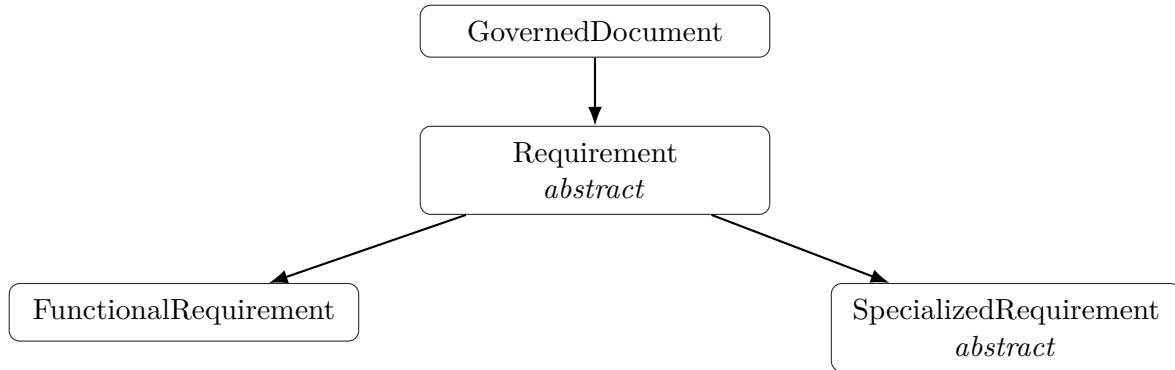


Figura 2: Candidate common abstraction for requirement documents.

```

Requirement [abstract]
  extends GovernedDocument

  normativeObligation : NormativeObligation [1]
  
```

L'astrazione e' giustificata solo se la proprieta' comune e' semantica e non una mera uniformita' editoriale.

4 Significato di NormativeObligation

NormativeObligation non e' un **FunctionalRequirement** e non e' inizialmente un documento governato autonomo. E' il contenuto normativo semanticamente coerente posseduto da un singolo **Requirement**.

```

Requirement [abstract]
  normativeObligation : NormativeObligation [1]

NormativeObligation
  normativeClause : NormativeClause [1..*]
  
```

Interpretazione candidata:

Un Requirement possiede una sola obbligazione normativa semanticamente coerente. L'obbligazione puo' richiedere una o piu' clausole normative per essere espressa completamente.

Quindi:

```

1 Requirement != 1 textual sentence
1 Requirement = 1 coherent normative obligation
  
```

Una obbligazione multi-clausola resta un solo Requirement soltanto finche' le clausole non diventano unita' di requisito indipendentemente significative, modificabili o valutabili.

OPEN - metaclass necessity test

Resta da falsificare se NormativeObligation debba essere una metaclassa L1 esplicita oppure se sia sufficiente modellare Requirement.normativeClause [1..*] con l'invariante che tutte le clausole costituiscano esattamente una obbligazione normativa coerente.

5 FunctionalRequirement come specializzazione

Forma candidata:

```
FunctionalRequirement
  extends Requirement

  parentDecision : Decision [1]
```

La normativeObligation ereditata rimane soggetta agli invarianti FR già chiusi:

- operationality;
- independent assessability;
- un solo comportamento, servizio, transizione o risultato osservabile coerente;
- completezza della correttezza funzionale ordinaria;
- implementation independence;
- normative prose primary.

L'introduzione di Requirement non rimuove alcun invariante FR. Il precedente concetto L1 functionalObligation è candidato a essere normalizzato come la Requirement.normativeObligation ereditata. Una rappresentazione L2 può conservare label specifiche per l'autoring, pur mantenendo una sola autorità semantica.

6 SpecializedRequirement come specializzazione

Forma candidata:

```
SpecializedRequirement [abstract]
  extends Requirement

  parentFunctionalRequirement : FunctionalRequirement [1]
```

La normativeObligation ereditata resta soggetta alle regole CLOSED S1:

- normative strengthening di esattamente un FR;
- composizione congiuntiva con il parent FR;
- removal test con preservazione della funzione ordinaria;
- nessuna duplicazione della correttezza funzionale;
- concern-specific obligation;
- positive subordinate action ammessa;
- autonomous capability boundary verso FR;
- realization independence;

- parent dependence.

L'astrazione comune non indebolisce la semantica S1.

7 Regression probes

Probe	Osservazione	Esito
FR-3.4 Deliver RecognitionCapture	Resta FR perche' l'obbligazione e' una responsabilita' operativa autonomamente significativa.	PASS
SR-3.4-C Confidentiality	Rafforza FR-3.4 senza definire la funzione di consegna.	PASS
SR-3.4-I Integrity	Usa lo stesso concetto di obbligazione senza perdere la semantica S1.	PASS
SR-3.4-P Authorized provenance	Puo' richiedere comportamento positivo subordinato senza diventare FR.	PASS
PerformanceRequirement illustrativo	Un target prestazionale concern-specific puo' usare la stessa astrazione senza essere FR.	PASS generality
RegulatoryRequirement illustrativo	Un obbligo normativo/compliance puo' usare la stessa astrazione senza essere FR.	PASS generality

7.1 Negative control - Decision

Una Decision e' governata e puo' contenere linguaggio prescrittivo, ma registra un commitment significativo che restringe un MR. Non e' una obbligazione di soddisfazione funzionale o specializzata.

Decision IS-NOT-A Requirement

NEGATIVE CONTROL - PASS

L'astrazione Requirement non si espande automaticamente a ogni GovernedDocument.

8 Stato candidato S1.5-A

STRONG CANDIDATE - Requirement abstraction

Requirement [abstract] e' candidato come superclass comune di FunctionalRequirement e SpecializedRequirement. Ogni Requirement possiede una sola obbligazione normativa semanticamente coerente, esprimibile mediante una o piu' clause.

Forma candidata:

```

Requirement [abstract]
  extends GovernedDocument
  normativeObligation : NormativeObligation [1]

NormativeObligation
  normativeClause : NormativeClause [1..*]

FunctionalRequirement

```

```
    extends Requirement
    parentDecision : Decision [1]

SpecializedRequirement [abstract]
    extends Requirement
    parentFunctionalRequirement : FunctionalRequirement [1]
```

Reopen criterion. Riaprire l'astrazione se una concreta sottoclasse di Requirement non puo' usare il contratto comune senza perdere semantica essenziale, oppure se l'astrazione forza documenti non-requirement a essere modellati come Requirement.

Parte B - Provenance constraints

9 Confine ereditato da S1

S1 ha già' distinto:

```
provenance = why an obligation/change exists
semantics  = what the governed obligation requires
```

Il meccanismo formale di provenance era deliberatamente deferred. Anche la change-impact semantics già' anticipa esiti di review quali:

```
retain
revise
replace
non-applicable
```

S1.5 deve quindi registrare il requisito futuro del modello, senza chiudere prematuramente AnalysisRecord, Finding, revision history o change-event machinery.

10 Analysis-to-document provenance requirement

CANDIDATE - provenance requirement

DDTA deve preservare provenance governata sufficiente a determinare quali cambiamenti accettati della documentazione siano stati motivati da ciascuna esecuzione di analisi e, inversamente, quali esecuzioni di analisi abbiano contribuito all'introduzione, revisione, sostituzione o retirement di ciascun documento governato.

Il requisito e' potenzialmente applicabile a:

```
MacroRequirement
Decision
FunctionalRequirement
SpecializedRequirement
```

Il caso facial-access MR-0004 mostra già' perché' la provenance futura non può' essere confinata ai soli Requirement: una review downstream ha motivato la revisione della decomposizione MR.

11 Invarianti di provenance preservabili ora

11.1 P1 - Provenance separation

CLOSED candidate P1

La provenance che spiega perché' un Requirement o altro documento governato e' stato introdotto, rivisto, sostituito o ritirato non appartiene alla sua obbligazione normativa.

Ne segue che un campo intrinseco obbligatorio del tipo:

```
SecurityRequirement.analysisId : exactly 1
```

non e' sufficiente né' corretto come semantica del Requirement.

11.2 P2 - Historical multiplicity

CLOSED candidate P2

Il futuro modello di provenance deve supportare una singola analisi con effetti su zero o molti documenti governati e un singolo documento governato con cambiamenti motivati da zero o molte analisi nel tempo.

one analysis execution

-> effects on zero or many governed documents

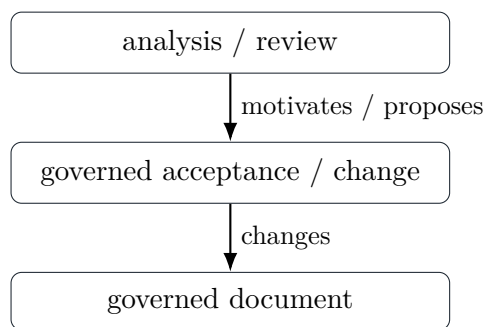
one governed document

-> effects motivated by zero or many analyses over time

11.3 P3 - Analysis is not governance authority

CLOSED candidate P3

Una analisi puo' motivare o proporre una modifica, ma non canonizza automaticamente documentazione governata.



11.4 P4 - Analyzed is not changed

CLOSED candidate P4

Il futuro modello deve distinguere un documento incluso nello scope di analisi da un documento effettivamente modificato, dopo governance review, a causa dell'analisi.

Una analisi che esamina FR-X e non produce alcuna modifica accettata non deve creare una falsa storia di cambiamento.

12 Meccanismo strutturale deliberatamente OPEN

La seguente forma e' soltanto illustrativa:

```

AnalysisRun
  |
  v
GovernedDocumentChangeEvent
  |
  v
GovernedDocument
  
```

Possibili event kind:

INTRODUCED
REVISED
REPLACED
RETIRED

OPEN - structural mechanism

S1.5 non chiude AnalysisRun, AnalysisRecord, Finding, GovernedDocumentChangeEvent, RequirementRevision, event ordering, supersession semantics, analysis scope/coverage, governance acceptance workflow o le cardinalita' esatte fra risultati analitici e cambiamenti accettati.

Questi concetti dovranno essere falsificati insieme al futuro modello di analisi.

13 Acceptance queries per il futuro modello

Qualunque struttura venga scelta dovra' permettere entrambe le direzioni di interrogazione.

13.1 Analysis verso accepted changes

```
AN-0042
+-- introduced SR-10
+-- introduced SR-11
+-- contributed to revision of FR-7
'-- contributed to retirement of SR-3
```

13.2 Governed document verso analysis lineage

```
SR-10
+-- introduced after AN-0042
+-- revised after AN-0071
'-- retired after AN-0108
```

Il modello deve inoltre consentire a una analisi di evidenziare un FunctionalRequirement ordinario mancante, senza costringere ogni output analitico a diventare SpecializedRequirement.

14 Stato epistemico S1.5

Stato	Elementi
CLOSED	Semantica operativa FR; semantica S1 SpecializedRequirement; SR esattamente un FR parent; provenance distinta dalla normative semantics; analisi non autorita' automatica della documentazione.
STRONG CANDIDATE	Requirement [abstract] come superclass comune di FR e SR; una sola obbligazione normativa coerente per Requirement; obbligazione esprimibile con una o piu' clausole.
CANDIDATE	Historical many-to-many analysis/change lineage; provenance piu' ampia di Requirement; analyzed $\neq$ changed; analysis motivates/proposes, governance accepts.

Stato	Elementi
OPEN	Contratto completo GovernedDocument; necessita' della metaclassa NormativeObligation; exact lifecycle/history model; ChangeEvent; RequirementRevision; AnalysisRun/AnalysisRecord; analysis type; change-kind vocabulary; supersession/retirement; structured applicability.
DEFERRED	Finding; Base Analysis/BAE; STRIDE; SecurityRequirement-specific provenance fields; controls; verification evidence.

15 Prossimo microstep raccomandato

1. Falsificare la necessita' di una metaclassa L1 **NormativeObligation** rispetto alla forma piu' minimale **Requirement.normativeClause [1..*]** con coherence invariant.
2. Se non emerge un controesempio, chiudere S1.5-A e normalizzare il contratto comune Requirement.
3. Conservare provenance come requisiti e acceptance queries, lasciando OPEN il meccanismo strutturale.
4. Avviare S2 con la sola ipotesi **SecurityRequirement IS-A SpecializedRequirement**.
5. Riprendere event/revision/provenance durante la formalizzazione di AnalysisRecord/Finding.

Conservation note

Questa nota deve restare materiale di lavoro fino a quando S1.5-A non viene falsificato o chiuso. La sua eventuale consolidazione nel Capitolo 4 deve preservare la distinzione fra contratto comune dei GovernedDocument, astrazione Requirement e provenance analitica.